LABORATUVAR 5: SBOM / CVE / PATCH YÖNETİMİ

Aes Group Raptor Ultra

1. Verilen Zafiyet Kaydı ve Hedef Sistem (SBOM) Eşleştirmesi

Avrupa Birliği Siber Dayanıklılık Yasası (**CRA - (AB) 2024/2847 Madde 14**) ve Yeni Makine Tüzüğü (**(AB) 2023/1230 Ek III**) uyarınca, AES Raptor Ultra CNC İşleme Merkezi'nin Yazılım Malzeme Listesi (**SBOM**) envanterinde yer alan kontrol bileşenine ilişkin zafiyet bildirimi aşağıda tanımlanmıştır:

Föy Parametresi	Verilen Zafiyet Kaydı	AES Raptor Ultra SBOM Karşılığı
Bileşen (Component)	Component X (PLC firmware kütüphanesi)	**AES PLC / OSAI-Syntec Hareket ve G/Ç İletişim Kütüphanesi** (Vakum bölgeleri, ATC karusel, pnömatik valfler ve NC Hops veri alışverişini yöneten TCP/IP-Modbus yığını)
Sürüm (Version)	2.4	**v2.4** (Sahadaki aktif üretim hattı bellenim sürümü)
CVE Kodu	CVE-XXXX-XXXX	**CVE-XXXX-XXXX** (Uzaktan Kod Çalıştırma / Bellek Taşması - Buffer Overflow zafiyeti)
Önem Derecesi	**Critical (CVSS 9.8)**	**Kritik (9.8 / 10.0)** – Ağ üzerinden kimlik doğrulamasız sömürülebilir, düşük karmaşıklık.
Yama Durumu	Mevcut (Available)	Üretici tarafından imzalı **v2.4.1 / v2.5** güvenlik yaması yayınlanmış durumda.

2. Görev: Zafiyet ve Yama Karar Akışı (Vulnerability Decision)

Soru 1: Bu CVE sizi gerçekten etkiliyor mu? (Üç şartın kontrolü)

Bir CVE kaydının makineyi siber-fiziksel olarak etkileyebilmesi için föyde belirtilen **üç temel şartın (Varlık, Sürüm, Ulaşılabilirlik)** aynı anda sağlanması gerekir. AES Raptor Ultra üzerinde yapılan SBOM ve mimari denetim sonuçları şöyledir:

1. **Şart 1 – Bileşen Makinede Var mı? (EVET):** AES Raptor Ultra'nın SBOM envanteri incelendiğinde; 12/16+10 istasyonlu ATC takım değiştiriciyi, 8–18 bölgeli Vacuboost alüminyum matris tablayı, Label X etiketleme istasyonunu ve eksen referanslarını yöneten **AES PLC** içerisinde *Component X (PLC firmware haberleşme kütüphanesi)* doğrudan yer almaktadır.
2. **Şart 2 – Sürüm Etkileniyor mu? (EVET):** Makinenin kontrol panosundaki (OSAI/Syntec + AES PLC) mevcut çalışan bellenim sürümü **v2.4** olup, CVE bülteninde savunmasız olduğu bildirilen sürüm ile birebir eşleşmektedir.

Şart 3 – Açık Ulaşılabilir mi / Exploit Path Var mı? (KISMEN EVET – MİMARİYE BAĞLI):

- **Geleneksel (Düz Ağ) Kurulumda:** Makine .DXF, .STL ve .STEP kesim dosyalarını almak için fabrika IT ağına (NC Hops / Alphacam PC katmanı) ve barkod okuyucuya doğrudan bağlı olduğundan, zafiyetli PLC portuna IT ağından (Conduit C4) doğrudan paket gönderilebilir. Açık **%100 ulaşılabilirdir**.
- **Hedef (IEC 62443 Segmentasyonlu) Kurulumda:** Lab 2 ve Lab 4'te kurgulanan Jump Server, güvenlik duvarı ve protokol kısıtlamaları dış ağdan doğrudan erişimi engeller; ancak **21 inç HMI / NC Hops PC** üzerinden PLC'ye doğru açık olan kontrol kanalından (Conduit) veya yetkili bir bakım bilgisayarından bu kütüphaneye hala ulaşılabilir.

Karar 1: Her üç şart da karşılandığından **bu CVE makinemizi doğrudan etkilemektedir**. Ayrıca **CRA Madde 14** uyarınca bu zafiyet sahada aktif olarak sömürülüyorsa, tespit anından itibaren **24 saat içinde ENISA/CSIRT Erken Uyarısı** ve **72 saat içinde Zafiyet Bildirimi** yapılması yasal zorunluluktur.

Soru 2: Üretimi hemen durdurur musunuz? Neden / Neden değil?

Karar 2: HAYIR, üretim derhal (panik halinde) durdurulmaz; mevcut kesim çevrimi (cycle) tamamlandıktan sonra kontrollü bakım penceresine geçilir.

Mühendislik ve Emniyet Gerekçeleri:

- **Bağımsız Emniyet Katmanı (OT Safety Zone İzolasyonu):** Lab 1 ve Lab 4'te doğrulandığı üzere, Raptor Ultra'nın insan hayatını koruyan birincil emniyet fonksiyonları (*Dikey/Yatay Işık Perdeleri, Lazer Alan Tarayıcı, Basınç Tamponları, Acil Durdurma Butonları, Handterminal Pro+ sinyal kesintisi rölesi ve Panasonic servoların STO - Safe Torque Off girişleri*) zafiyetli olan standart **AES PLC (Component X)** üzerinde değil, ondan fiziksel olarak izole edilmiş çift kanallı **Safety PLC / Emniyet Rölesi (PL d / PL e)** üzerinde çalışmaktadır. Standart PLC'de CVSS 9.8'lik bir açık bulunsa dahi, donanımsal emniyet zinciri hala aktiftir ve operatörü korumaktadır.
- **Ani Duruşun (Hard Stop) Yaratacağı Fiziksel Tehlike:** Makine 24.000 RPM hızda dönen 14 kW HSD iş mili ile ağır masif ahşap veya alüminyum keserken ya da 100 m/dk hızla portal hareket halindeyken üretimin plansızca kesilmesi; kesici takımın malzeme içinde sıkışarak kırılmasına, termal sürtünme ile talaş yangınına veya vakum (Vacuboost) kontrolünün zamansız kesilmesiyle iş parçasının savrulmasına (*ejection hazard*) yol açabilir.
- **İlk Aksiyon:** Üretimi durdurmak yerine, zafiyetin dışarıdan tetiklenmesini önlemek amacıyla makinenin fabrika IT/ERP ağı ve uzaktan erişim bağlantısı (*Conduit C1 ve C4*) güvenlik duvarı üzerinden anında izole edilir (*Ağ Karantinası*); makine mevcut iş emrini yerel (standalone) modda güvenle tamamlar.

Soru 3: Yamayı doğrudan mı uygularsınız, önce test mi? Nerede test?

Karar 3: Yama kesinlikle doğrudan sahadaki (canlı) makineye uygulanmaz; önce izole test ortamında doğrulanır.

Neden Doğrudan Uygulanmaz? Endüstriyel CNC ve PLC sistemlerinde bir firmware kütüphanesi yaması (*Component X v2.4 → v2.5*), gerçek zamanlı (*real-time*) çevrim sürelerini (scan time), bellek adreslemelerini veya zamanlama (jitter) parametrelerini değiştirebilir. Doğrudan canlı makineye yüklenen test edilmemiş bir yama:

- 100 m/dk hızla hareket eden 1000 kg kütleli portal köprünün eksen interpolasyonunu bozarak mekanik çarpışmaya,
- 12/16+10 istasyonlu döner ATC magazininde *anti-crash* sensör zamanlamasını kaydırarak HSK-F63 takım bindirmesine,

- 5 Bar pnömatik basınç ve Becker vakum pompası bölge valflerinin senkronizasyon kaybına neden olabilir.

Nerede ve Nasıl Test Edilir? (3 Aşamalı Test Protokolü):

Aşama 1: Bursa NOSAB Ar-Ge / HIL (Hardware-in-the-Loop) Test Masası (Staging Bench): Yama ilk olarak AES Group'un fabrika laboratuvarındaki fiziksel eşdeğer kontrol panosunda (*OSAI/Syntec CNC + AES PLC + Panasonic Servo Sürücü test standı*) ve **NC Hops 3D Katı Model / Çarpışma Simülasyonu** ortamında yüklenir. Kriptografik imza (*Secure Boot*) doğrulaması kontrol edilir.

Aşama 2: Makine Üzerinde Boşta (Dry-Run / Air-Cut) Testi: Test masasından onay alan yama, sahadaki Raptor Ultra'ya mesai dışı bakım penceresinde yüklenir. İş miline kesici takım takılmadan (*HSK-F63 yüksüz*) ve tablada malzeme yokken; 100 m/dk eksen hareketleri, ATC takım değiştirme çevrimi ve Vacuboost valf geçişleri boşta çalıştırılarak PLC döngü süresi (scan time) izlenir.

Aşama 3: Yük Altında İlk Parça (First-Article) Doğrulaması: Standart bir MDF plaka üzerinde tam yükte kesim ve DH serisi çoklu delik operasyonu yapılarak boyutsal hassasiyet (±0.05 mm) teyit edilir.

Soru 4: Bu yama bir Safety Validation (Emniyet Doğrulaması) etkiliyor mu? Nasıl anlarsınız?

Karar 4: Doğrudan Safety PLC mantığını değiştirmese bile, standart PLC ile emniyet devresi arasındaki etkileşim nedeniyle KISMİ EMNİYET DOĞRULAMASI (Partial Safety Re-validation) gerektirir.

Bir Yamanın Safety Validation'ı Etkileyip Etkilemediğini Anlama Kriterleri (Etki Analizi):

1. **CRC / Checksum (Sağlama Toplamı) Kontrolü:** EN ISO 13849-1 ve (AB) 2023/1230 Ek III Madde 1.2.1 uyarınca, Safety PLC üzerindeki onaylı emniyet yazılımının benzersiz bir kriptografik özeti (*Safety Signature / CRC*) vardır. Yama sonrasında Safety PLC'nin CRC değeri değişmemişse, çekirdek emniyet mantığı bozulmamıştır.

2. **Duruş Süresi ($T = t_1 + t_2$) ve Güvenlik Mesafesi (S) Kontrolü (EN ISO 13855):** Raptor Ultra'da **Kategori 1 duruş** (örneğin 5 Bar pnömatik basınç veya vakum düşümünde kontrollü rampa ile durma) standart PLC ve CNC sürücülerinin frenleme rampasını kullanır. Eğer *Component X* yaması PLC'nin tepki süresini (t_1) veya sürücüye giden frenleme komutunu (t_2 = 250 ms) geciktirirse, Lab 3'te hesaplanan minimum ışık perdesi mesafesi ($S = (K \times T) + C = 621$ mm) geçersiz hale gelir!

3. **İş Mili Kilitleme (Spindle Interlock - EN ISO 19085-3 Madde 5.3.2):** HSD iş mili 24.000 RPM ile dönerken 0 RPM'e düşmeden HSK-F63 pensinin açılmasını engelleyen kilitleme sinyali ve ≤ 10 sn duruş süresi kontrol edilir.

Doğrulama Testi: Yama uygulandıktan sonra makine tam hızda (100 m/dk) çalışırken **Duruş Süresi Ölçüm Cihazı (Stopping Time Meter)** ile ışık perdesi kesilir; toplam duruş süresinin $T \leq 0.308$ sn sınırının altında kaldığı ve **5 Yıllık İzleme Kaydına (Tracing Log)** yeni yazılım versiyonunun işlendiği görülerek emniyet doğrulaması tamamlanır.

Soru 5: Yama mümkün değilse Compensating Control (Telafi Edici Önlem) ne olur?

Eğer yama eski nesil (legacy) bir OSAI/Syntec donanımıyla uyumsuzsa, üretimi bozuyorsa veya onaylı test süreci tamamlanana kadar makinenin çalışması gerekiyorsa, IEC 62443-3-3 ve CRA kapsamında aşağıdaki **Telafi Edici Önlemler (Compensating Controls)** derhal devreye alınır:

Telafi Edici Önlem Katmanı	AES Raptor Ultra Üzerindeki Spesifik Teknik Uygulama
1. Ağ İzolasyonu ve Port Kapatma (Conduit Kısıtlama)	Zafiyetli *Component X* kütüphanesinin kullandığı TCP/UDP portları, OT Güvenlik Duvarı (Firewall) üzerinde dış ağa ve fabrika IT ağına (Conduit C1 ve C4) tamamen kapatılır. PLC'ye sadece 21 inç yerel HMI ekranının sabit IP/MAC adresinden erişime izin verilir (*IP/MAC Whitelisting*).
2. Sanal Yamalama (Virtual Patching / IDS-IPS)	CNC/PLC önüne yerleştirilen endüstriyel güvenlik duvarı üzerinde **Derin Paket İnceleme (DPI)** devreye alınır. CVE-XXXX-XXXX zafiyetini tetikleyen aşırı uzunluktaki paketler (*buffer overflow payload*) PLC'ye ulaşmadan ağ katmanında düşürülür.
3. Uzaktan Erişimin Fiziksel Kilitlenmesi	Lab 4'te tanımlanan uzaktan bakım erişimi tamamen devre dışı bırakılır. Pano üzerindeki fiziksel **"Uzaktan Bakım Yetki Anahtarı"** *LOCAL (Kapalı)* konumuna alınarak kilitlenir.
4. Fiziksel ve Çevresel Arayüz Kısıtlaması	Kesim listelerinin (.DXF/.STEP) ağ yerine taşınabilir belleklerle yüklenmesi gerekiyorsa, HMI üzerindeki USB portları yalnızca kriptografik olarak doğrulanmış ve zararlı yazılım taramasından geçmiş tek bir endüstriyel belleğe izin verecek şekilde sınırlandırılır.
5. Donanımsal PLC Yazma Koruması (Run/Program Key)	AES PLC üzerindeki fiziksel mod anahtarı **"RUN" (Salt-Okunur Çalışma)** konumuna getirilerek anahtar çıkarılır; böylece kütüphane üzerinden çalışma zamanında (runtime) bellek veya parametre değiştirilmesi donanımsal olarak engellenir.

Sonuç ve Teknik Dosya (TCF) Kaydı: Bu karar akışı, **(AB) 2023/1230 Makine Tüzüğü Ek III Madde 1.1.9** ve **(AB) 2024/2847 CRA** kapsamında **Evidence Pack EP 09 (SBOM)**, **EP 10 (Vulnerability Management)** ve **EP 11 (Patch & Safety Re-validation)** kanıt paketlerine resmi uygunluk kaydı olarak eklenmiştir.